

Full Decision Tree Question Matrix (en)

Generated from decisionTreeModel.js and src/locales/en/model.json

A1 (question)

Question: Is the proposed solution an AI System according to the EU AI Act?
Description: First, it is asserted whether the proposed solution fulfills the definition of an AI system. Only if this is true, other requirements of the EU AI Act are relevant.
Yes: A2 No: A0 Next: -
Reference: EU AI Act (2024), Art. 3

A0 (leaf)

Question: Not an AI system -> EU AI Act not applicable.
Description: If the system does not fall under the definition of an AI system, the specific EU AI Act obligations do not apply. DORA and internal governance/security requirements may still be relevant.
Yes: - No: - Next: ENDE
Reference: EU AI Act (2024), Art. 3

A2 (question)

Question: Is there a potentially prohibited practice under the EU AI Act?
Description: This step checks whether the AI system falls into a category that is generally prohibited under the EU AI Act. If a prohibited practice applies, use is generally not allowed.
Yes: A2_Y No: A2_ROLLE Next: -
Reference: EU AI Act (2024), Art. 5

A2_Y (leaf)

Question: Prohibited practice -> prohibit use and trigger escalation.
Description: Prohibited practices are generally not allowed. Initiate escalation and stop the use of the system.
Yes: - No: - Next: D1
Reference: EU AI Act (2024), Art. 5

G_AI_VERBOTENE_PRAKTIKEN_UEBERPRUEFUNG (question)

Question: Review gate: Has use been stopped and the escalation documented?
Description: Ensures that prohibited practices are not pursued further without a formal stop/escalation decision.
Yes: ENDE No: W_KI_WIDERSPRUCH Next: -
Reference: EU AI Act (2024), Art. 5

A2_ROLLE (question)

Question: Are you the deployer or provider of the AI system being integrated?
Description: This step clarifies the company's role in the specific use case. The relevant definitions can be found in Art. 3 paras. 3-4.
Yes: A2_ROLLE_BEREITSTELLUNG No: A2_ROLLE_BETRIEB_KONTROLLE Next: -
Reference: EU AI Act (2024), Art. 3

A2_ROLLE_BEREITSTELLUNG (question)

Question: Do you make the AI system available to third parties (or a variant under your brand) or place it on the market?
Description: Practical provider indicator: you make the system/product available to third parties.
Yes: A2_ROLLE_WESENTLICHE_AENDERUNG No: A2_ROLLE_WESENTLICHE_AENDERUNG Next: -
Reference: EU AI Act (2024)

A2_ROLLE_WESENTLICHE_AENDERUNG (question)

Question: Do you make substantial changes to the model/system that go beyond pure configuration?
Description: "Substantial modification" is a strong provider indicator. Pure configuration typically does not count.
Yes: A2_ROLLE_BETRIEB_KONTROLLE No: A2_ROLLE_BETRIEB_KONTROLLE Next: -
Reference: EU AI Act (2024)

A2_ROLLE_BETRIEB_KONTROLLE (question)

Question: Do you have operational control over the production AI component, or do you control key operating parameters, regardless of where it is hosted?
Description: "Hosting" (where it runs) is not the same as "operations" (who controls it). Answer "Yes" if you control production operation or define parameters that materially influence behaviour and risk profile. This is a strong indicator that you carry deployer obligations and, in certain constellations, may also move into the provider role.
Yes: A2_ROLLE_BETREIBER_EINSATZZWECK No: A2_ROLLE_BETREIBER_EINSATZZWECK Next: -
Reference: EU AI Act (2024)

A2_ROLLE_BETREIBER_EINSATZZWECK (question)

Question: Do you use the AI system in your own business process and determine its purpose and deployment context?
Description: A deployer is typically the party that uses an AI system in its own process and defines the usage context.
Yes: A2_ROLLE_BETREIBER_DATENVERANTWORTUNG No: A2_ROLLE_SCOPE_UN SICHER Next: -
Reference: EU AI Act (2024)

A2_ROLLE_BETREIBER_DATENVERANTWORTUNG (question)

Question: Do you provide key input data and take responsibility for its selection/quality?
Description: In practice, whoever provides relevant input data and is responsible for its use is usually the deployer or carries deployer obligations.
Yes: A2_ROLLE_KONFORMITAETSARTEFAKTE No: A2_ROLLE_SCOPE_UN SICHER Next: -
Reference: EU AI Act (2024)

A2_ROLLE_KONFORMITAETSA RTEFAKTE (question)

Question: Do you provide the key evidence and documentation for conformity or security yourself?

Description: If you must prepare or deliver the central documentation yourself, that is a strong indicator of the "provider" role.

Yes: A2_ROLLE_SCOPE_ANBIETER No: A2_ROLLE_SCOPE_BETREIBER Next: -

Reference: EU AI Act (2024)

A2_ROLLE_SCOPE_ANBIETER (leaf)

Question: Role recommendation: Provider

Description: -

Yes: - No: - Next: A2_GPAI_ANBIETER

Reference: EU AI Act (2024)

A2_ROLLE_SCOPE_BETREIBER (leaf)

Question: Role recommendation: Deployer

Description: -

Yes: - No: - Next: A2_GPAI_BETREIBER

Reference: EU AI Act (2024) – Rollenklärung (intern)

A2_ROLLE_SCOPE_UNSICHER (leaf)

Question: Role unclear (uncertain)

Description: The answers are inconsistent.

Yes: - No: - Next: A2_GPAI_UNSICHER

Reference: EU AI Act (2024)

A2_GPAI_ANBIETER (question)

Question: Is a general-purpose AI model (GPAI) being used?

Description: A GPAI is a model that can be used for many different tasks and is not limited to one narrowly defined purpose. The term general-purpose AI is defined in Art. 3 para. 63.

Yes: A2_GPAI_SCREENING_ANBIETER No: A3_HR_ANHANG_III_DOMAENE_ANBIETER_FINANZ Next: -

Reference: EU AI Act (2024), Art. 51–52

A2_GPAI_SCREENING_ANBIETER (leaf)

Question: GPAI detected -> review screening and supply-chain transparency

Description: Carry out the screening first; then clarify whether systemic risk is involved.

Yes: - No: - Next: A2_GPAI_SYSTEMRISIKO_ANBIETER

Reference: EU AI Act (2024), Art. 51–52

A2_GPAI_SYSTEMRISIKO_ANBIETER (question)

Question: Is this a GPAI with systemic risk?

Description: A GPAI with systemic risk is a model with very high capability and broad applicability whose use may have potentially large-scale, severe effects beyond individual cases. Indicators include very broad reach/adoption, high scalability, central dependency of many processes/products, and an increased potential for significant harm.

Yes: A2_GPAI_SYSTEMRISIKO_Y_ANBIETER No: A3_HR_ANHANG_III_DOMAENE_ANBIETER_FINANZ Next: -

Reference: EU AI Act (2024), Art. 55

A2_GPAI_SYSTEMRISIKO_Y_ANBIETER (leaf)

Question: GPAI with systemic risk -> additional obligations

Description: -

Yes: - No: - Next: A3_HR_ANHANG_III_DOMAENE_ANBIETER_FINANZ

Reference: EU AI Act (2024), Art. 55

A2_GPAI_BETREIBER (question)

Question: Is a general-purpose AI model (GPAI) being used?

Description: A GPAI is a model that can be used for many different tasks and is not limited to one narrowly defined purpose. The term general-purpose AI is defined in Art. 3 para. 63.

Yes: A2_GPAI_SCREENING_BETREIBER No: A3_HR_ANHANG_III_DOMAENE_BETREIBER_FINANZ Next: -

Reference: EU AI Act (2024), Art. 51–52

A2_GPAI_SCREENING_BETREIBER (leaf)

Question: GPAI detected -> review screening and supply-chain transparency

Description: Carry out the screening first; then clarify whether systemic risk is involved.

Yes: - No: - Next: A2_GPAI_SYSTEMRISIKO_BETREIBER

Reference: EU AI Act (2024), Art. 51–52

A2_GPAI_SYSTEMRISIKO_BETREIBER (question)

Question: Is this a GPAI with systemic risk?

Description: A GPAI with systemic risk is a model with very high capability and broad applicability whose use may have potentially large-scale, severe effects beyond individual cases. Indicators include very broad reach/adoption, high scalability, central dependency of many processes/products, and an increased potential for significant harm.

Yes: A2_GPAI_SYSTEMRISIKO_Y_BETREIBER No: A3_HR_ANHANG_III_DOMAENE_BETREIBER_FINANZ Next: -

Reference: EU AI Act (2024), Art. 55

A2_GPAI_SYSTEMRISIKO_Y_BETREIBER (leaf)

Question: GPAI with systemic risk -> additional obligations (Art. 55)

Description: -

Yes: - No: - Next: A3_HR_ANHANG_III_DOMAENE_BETREIBER_FINANZ

Reference: EU AI Act (2024), Art. 55

A2_GPAI_UNSICHER (question)

Question: Is a general-purpose AI model (GPAI) being used?

Description: A GPAI is a model that can be used for many different tasks and is not limited to one narrowly defined purpose. The term general-purpose AI is defined in Art. 3 para. 63.

Yes: A2_GPAI_SCREENING_UNSICHER No: A3_HR_ANHANG_III_DOMAENE_ANBIETER_FINANZ Next: -

Reference: EU AI Act (2024), Art. 51–52

A2_GPAI_SCREENING_UNSICHER (leaf)

Question: GPAI detected -> review screening and supply-chain transparency

Description: Carry out the screening first; then clarify whether systemic risk is involved.

Yes: - No: - Next: A2_GPAI_SYSTEMRISIKO_UNSICHER

Reference: EU AI Act (2024), Art. 51–52

A2_GPAI_SYSTEMRISIKO_UNSICHER (question)

Question: Is this a GPAI with systemic risk?

Description: A GPAI with systemic risk is a model with very high capability and broad applicability whose use may have potentially large-scale, severe effects beyond individual cases. Indicators include very broad reach/adoption, high scalability, central dependency of many processes/products, and an increased potential for significant harm.

Yes: A2_GPAI_SYSTEMRISIKO_Y_UNSICHER No: A3_HR_ANHANG_III_DOMAENE_ANBIETER_FINANZ Next: -

Reference: EU AI Act (2024), Art. 55

A2_GPAI_SYSTEMRISIKO_Y_UNSICHER (leaf)

Question: GPAI with systemic risk -> additional obligations

Description: -

Yes: - No: - Next: A3_HR_ANHANG_III_DOMAENE_ANBIETER_FINANZ

Reference: EU AI Act (2024), Art. 55

A3_HR_ANHANG_III_DOMAENE_ANBIETER_FINANZ (question)

Question: Does the Annex III domain "finance" apply?

Description: If this domain applies, high-risk classification is very likely. If uncertain, choose yes conservatively and document the review.

Yes: A3_HR_FIN_KREDIT_ANBIETER No: A3_HR_ANHANG_III_DOMAENE_ANBIETER_SICHERHEITSBAUTEIL Next: -

Reference: EU AI Act (2024), Anhang III

A3_HR_ANHANG_III_DOMAENE_ANBIETER_SICHERHEITSBAUTEIL (question)

Question: Is the AI system a safety component or part of a product under Art. 6?

Description: A safety component is a hardware/software component of a product that performs a protective function or is essential to safe use.

Yes: A3_HR_ANBIETER No: A3_HR_ANHANG_III_DOMAENE_ANBIETER_BIOMETRIE Next: -

Reference: EU AI Act (2024), Art. 6

A3_HR_ANHANG_III_DOMAENE_ANBIETER_BIOMETRIE (question)

Question: Does the Annex III domain "biometrics" apply?

Description: -

Yes: A3_HR_ANBIETER No: A3_HR_ANHANG_III_DOMAENE_ANBIETER_KRIT_INFRA Next: -

Reference: EU AI Act (2024), Anhang III

A3_HR_ANHANG_III_DOMAENE_ANBIETER_KRIT_INFRA (question)

Question: Does the Annex III domain "critical infrastructure" apply?

Description: -

Yes: A3_HR_ANBIETER No: A3_HR_ANHANG_III_DOMAENE_ANBIETER_BILDUNG_ARBEIT_DIENSTE Next: -

Reference: EU AI Act (2024), Anhang III

A3_HR_ANHANG_III_DOMAENE_ANBIETER_BILDUNG_ARBEIT_DIENSTE (question)

Question: Does any of the Annex III domains apply: education, employment/personnel management, or access to essential services?

Description: This combined question reduces false negatives when the use case is not "finance" but may still fall under Annex III.

Yes: A3_HR_ANBIETER No: A3_ANBIETER Next: -

Reference: EU AI Act (2024), Anhang III

A3_HR_FIN_KREDIT_ANBIETER (question)

Question: Is the AI system intended for creditworthiness/credit scoring of natural persons (excluding pure financial fraud detection)?

Description: If the system is intended for creditworthiness/credit scoring, this is an explicit high-risk use case. Exception: pure financial fraud detection is excluded.

Yes: A3_HR_ANBIETER No: A3_HR_FIN_VERSICHERUNGS_ANBIETER Next: -

Reference: EU AI Act (2024), Anhang III

A3_HR_FIN_VERSICHERUNGS_ANBIETER (question)

Question: Is the AI system intended for risk assessment and pricing in life/health insurance for natural persons?

Description: Pricing/risk assessment in life and health insurance for natural persons is an explicit high-risk use case.

Yes: A3_HR_ANBIETER No: A3_ANBIETER Next: -

Reference: EU AI Act (2024), Anhang III

A3_ANBIETER (question)

Question: None of the previous Annex III/Art. 6 triggers applied clearly: is there nevertheless a high-risk case that must be documented?

Description: If yes, proceed conservatively as high-risk. The rationale/boundary assessment (Annex III/Art. 6) must be documented in an audit-ready manner.

Yes: A3_HR_ANBIETER No: A3_KEIN_HR_PRUEFUNG Next: -

Reference: EU AI Act (2024), Art. 6

A3_HR_ANBIETER (leaf)

Question: High-risk AI -> apply high-risk obligations.

Description: The system is classified as high-risk AI. This triggers the extensive obligations (including risk, data, and governance requirements).

Yes: - No: - Next: D0

Reference: EU AI Act (2024), Art. 6

A3_HR_ANHANG_III_DOMAENE_BETREIBER_FINANZ (question)

Question: Does the Annex III domain "finance" apply?

Description: If this domain applies, high-risk classification is very likely. If uncertain, choose yes conservatively and document the review.

Yes: A3_HR_FIN_KREDIT_BETREIBER No: A3_HR_ANHANG_III_DOMAENE_BETREIBER_SICHERHEITSBAUTEIL Next: -

Reference: EU AI Act (2024), Anhang III

A3_HR_ANHANG_III_DOMAENE_BETREIBER_SICHERHEITSBAUTEIL (question)

Question: Is the AI system a safety component or part of a product under Art. 6?

Description: A safety component is a hardware/software component of a product that performs a protective function or is essential to safe use.

Yes: A3_HR_BETREIBER No: A3_HR_ANHANG_III_DOMAENE_BETREIBER_BIOMETRIE Next: -

Reference: EU AI Act (2024), Art. 6

A3_HR_ANHANG_III_DOMAENE_BETREIBER_BIOMETRIE (question)

Question: Does the Annex III domain "biometrics" apply?

Description: -

Yes: A3_HR_BETREIBER No: A3_HR_ANHANG_III_DOMAENE_BETREIBER_KRIT_INFRA Next: -

Reference: EU AI Act (2024), Anhang III

A3_HR_ANHANG_III_DOMAENE_BETREIBER_KRIT_INFRA (question)

Question: Does the Annex III domain "critical infrastructure" apply?

Description: -

Yes: A3_HR_BETREIBER No: A3_HR_ANHANG_III_DOMAENE_BETREIBER_BILDUNG_ARBEIT_DIENSTE Next: -

Reference: EU AI Act (2024), Anhang III

A3_HR_ANHANG_III_DOMAENE_BETREIBER_BILDUNG_ARBEIT_DIENSTE (question)

Question: Does any of the Annex III domains apply: education, employment/personnel management, or access to essential services?

Description: This combined question reduces false negatives when the use case is not "finance" but may still fall under Annex III.

Yes: A3_HR_BETREIBER No: A3_BETREIBER Next: -

Reference: EU AI Act (2024), Anhang III

A3_HR_FIN_KREDIT_BETREIBER (question)

Question: Is the AI system intended for creditworthiness/credit scoring of natural persons (excluding pure financial fraud detection)?

Description: If the system is intended for creditworthiness/credit scoring, this is an explicit high-risk use case. Exception: pure financial fraud detection is excluded.

Yes: A3_GRFA_TRIGGER_BETREIBER No: A3_HR_FIN_VERSICHERUNGS_BETREIBER Next: -

Reference: EU AI Act (2024), Anhang III

A3_HR_FIN_VERSICHERUNGS_BETREIBER (question)

Question: Is the AI system intended for risk assessment and pricing in life/health insurance for natural persons?

Description: Pricing/risk assessment in life and health insurance for natural persons is an explicit high-risk use case.

Yes: A3_GRFA_TRIGGER_BETREIBER No: A3_BETREIBER Next: -

Reference: EU AI Act (2024), Anhang III

A3_BETREIBER (question)

Question: None of the previous Annex III/Art. 6 triggers applied clearly: is there nevertheless a high-risk case (for example another Annex III domain) that must be documented?

Description: If yes, proceed conservatively as high-risk. The rationale/boundary assessment (Annex III/Art. 6) must be documented in an audit-ready manner.

Yes: A3_GRFA_TRIGGER_BETREIBER No: A3_KEIN_HR_PRUEFUNG Next: -

Reference: EU AI Act (2024), Art. 6

A3_HR_BETREIBER (leaf)

Question: High-risk AI -> apply high-risk obligations.

Description: The system is classified as high-risk AI. This triggers the extensive obligations (including risk, data, and governance requirements).

Yes: - No: - Next: D0

Reference: EU AI Act (2024), Art. 6

A3_GRFA_HEUR_ZUGANG_WESENTLICHE_DIENSTE (question)

Question: Can the system influence access to essential services/opportunities (directly or in practice)?

Description: FRIA risk indicator: if outcomes/decision access are influenced, a fundamental-rights impact is plausible.

Yes: A3_GRFA_HEUR_DISKRIMINIERUNG No: A3_GRFA_HEUR_DISKRIMINIERUNG Next: -

Reference: EU AI Act (2024), Art. 27

A3_GRFA_HEUR_DISKRIMINIERUNG (question)

Question: Is there a plausible discrimination/fairness risk?

Description: FRIA is often triggered by discrimination risks (especially in decisions affecting persons).

Yes: A3_GRFA_HEUR_VULNERABLE_GRUPPEN No: A3_GRFA_HEUR_VULNERABLE_GRUPPEN Next: -

Reference: EU AI Act (2024), Art. 27

A3_GRFA_HEUR_VULNERABLE_GRUPPEN (question)

Question: Are vulnerable groups affected, or is a special need for protection plausible?

Description: The greater the need for protection, the more appropriate a conservative FRIA approach becomes.

Yes: A3_GRFA_HEUR_AUTOMATISIERUNGSGRAD No: A3_GRFA_HEUR_AUTOMATISIERUNGSGRAD Next: -

Reference: EU AI Act (2024), Art. 27

A3_GRFA_HEUR_AUTOMATISIERUNGSGRAD (question)

Question: Are recommendations typically accepted, or are control options limited?

Description: If the AI is effectively decision-driving, fundamental-rights risk increases.

Yes: A3_GRFA_TRIGGER_BETREIBER No: A3_GRFA_TRIGGER_BETREIBER Next: -

Reference: EU AI Act (2024), Art. 27

A3_GRFA_TRIGGER_BETREIBER (question)

Question: Is a fundamental rights impact assessment (FRIA) under Art. 27 required for this high-risk use case?

Description: FRIA is not limited to financial use cases. It must be assessed in context, for example for high-risk use cases under Annex III or where deployment may have significant effects on fundamental rights. Even if FRIA is not required, the obligation review (note/rationale) must still be documented in an audit-ready manner.

Yes: A3_HR_BETREIBER_GRFA No: A3_HR_BETREIBER_OHNE_GRFA Next: -

Reference: EU AI Act (2024), Art. 27

W_KI_GRFA_REVIEW (leaf)

Question: FRIA: Conservative review required.

Description: At least one FRIA trigger was answered with yes. If uncertain, continue conservatively as if FRIA were required until the review is completed.

Yes: - No: - Next: A3_HR_BETREIBER_GRFA

Reference: EU AI Act (2024), Art. 27

A3_HR_BETREIBER_GRFA (leaf)

Question: High-risk AI -> apply deployer obligations (including FRIA under Art. 27).

Description: FRIA is required: in addition to deployer obligations, FRIA documentation, review/approval, and action tracking must be implemented and evidenced.

Yes: - No: - Next: D0

Reference: EU AI Act (2024), Art. 26–27

A3_HR_BETREIBER_OHNE_GRFA (leaf)

Question: High-risk AI -> apply deployer obligations (FRIA not required; document the obligation review).

Description: FRIA is not required: no full FRIA package is triggered, but the FRIA obligation review itself (note/rationale) must be evidenced in an audit-ready way.

Yes: - No: - Next: D0

Reference: EU AI Act (2024), Art. 26–27

A3_KEIN_HR_PRUEFUNG (question)

Question: No high-risk classification identified: is that classification transparently justified in an appropriate document?

Description: Art. 50 does not apply automatically to non-high-risk systems. Before transparency is reviewed, the non-high-risk classification should be documented in a traceable way.

Yes: A4_TRANSPARENZ_ANWENDBAR No: A4_TRANSPARENZ_ANWENDBAR Next: -

Reference: EU AI Act (2024), Art. 6

A4_TRANSPARENZ_ANWENDBAR (question)

Question: Does the system interact directly with natural persons, or does it generate synthetic content (text/image/audio/video) that must be labeled?

Description: Art. 50 is typically triggered by direct interaction with people or by synthetic content that requires disclosure/labelling.

Yes: A4_KEIN_HR_MIT_TRANSPARENZPFLICHTEN No: A4_KEIN_HR_NUR_GOVERNANCE_BASIS Next: -

Reference: EU AI Act (2024), Art. 50

A4_KEIN_HR_MIT_TRANSPARENZPFLICHTEN (leaf)

Question: No high-risk classification -> Art. 50 transparency obligations apply.

Description: The system remains non-high-risk, but transparency requirements apply due to interaction/content output. AI literacy/knowledge must also be ensured.

Yes: - No: - Next: D0

Reference: EU AI Act (2024), Art. 50

A4_KEIN_HR_NUR_GOVERNANCE_BASIS (leaf)

Question: No high-risk classification -> no Art. 50 triggers -> only ensure knowledge obligations.

Description: If no Art. 50 transparency triggers apply, the clear AI Act obligation remaining in the tool is to ensure AI literacy/knowledge.

Yes: - No: - Next: D0

Reference: EU AI Act (2024), Art. 4

W_KI_HR_UEBERPRUEFUNG (leaf)

Question: Warning: High-risk classification unclear -> review and documentation required.

Description: This node requires formal clarification before integration continues.

Yes: - No: - Next: ENDE

Reference: EU AI Act (2024), Art. 6

W_KI_WIDERSPRUCH (leaf)

Question: Contradiction detected -> review/escalation required.

Description: Inconsistent answers should not lead to silent assumptions or implicit downgrading.

Yes: - No: - Next: ENDE

Reference: -

A3_HR_BETREIBER_FIN (leaf)

Question: High-risk AI (finance, Annex III, point 5) -> apply deployer obligations including FRIA.

Description: FRIA is not limited to financial cases; it must be assessed in context (Art. 27). The decision tree therefore performs a separate FRIA decision and only triggers the full FRIA obligations if the answer is yes. If no, at least the obligation review itself (note/rationale) is still required as evidence.

Yes: - No: - Next: D0

Reference: EU AI Act (2024), Anhang III

D0 (question)

Question: Does your organization fall within the scope of DORA?

Description: DORA only applies to financial entities within the meaning of Art. 2. If your organization does not fall within that scope, the DORA review is not continued.

Yes: D1_ART16_B4 No: ENDE Next: -

Reference: DORA (2022), Art. 2

D1_ART16_B4 (question)

Question: May a simplified ICT risk management framework under Art. 16 be applied to your organization?

Description: Art. 16 is not a general scaling-down based on size, but an explicitly regulated exception for certain, mostly smaller or exempt financial entities. For these entities, the detailed requirements of Arts. 5-15 do not apply; instead, a simplified ICT risk management framework is permitted.

Yes: D1_ART16_Y_B4 No: D1_ART16_N_B4 Next: -

Reference: DORA (2022), Art. 16

D1_ART16_Y_B4 (leaf)

Question: Art. 16 applicable -> implement simplified ICT RMF (minimum requirements).

Description: The light variant is audit-ready here because it is explicitly based on Art. 16, including supporting evidence.

Yes: - No: - Next: B1

Reference: DORA (2022), Art. 16

D1_ART16_N_B4 (leaf)

Question: Art. 16 not applicable -> scaled baseline requirements.

Description: A scaled implementation is permissible, but the rationale must be traceable: Art. 16 is NOT the legal basis.

Yes: - No: - Next: B1

Reference: DORA (2022), Art. 4 i. V. m. Art. 5–15

B1 (question)

Question: Does the AI system support a critical or important function?

Description: This question clarifies whether the AI system is used in processes that are critical or important for the organization. That determines how strict the ICT risk management and resilience requirements under DORA need to be. The exact definition can be found in Art. 3(22).

Yes: B1_SCOPE_NACHWEIS No: B3 Next: -

Reference: DORA (2022), Art. 3

B1_SCOPE_NACHWEIS (question)

Question: Is the classification as a critical or important function documented and approved in a traceable way?

Description: For the classification to be audit-ready, the scope must be derived cleanly: which process is affected, which dependencies exist, and which impact/time tolerances apply.

Yes: B2 No: W_DORA_KRITISCHE_FUNKTION_SCOPE_UEBERPRUEFUNG Next: -

Reference: DORA (2022), Art. 8

W_DORA_KRITISCHE_FUNKTION_SCOPE_UEBERPRUEFUNG (leaf)

Question: Evidence for critical/important function missing -> complete documentation/approval.

Description: Without evidence on scope, dependencies, and tolerances, the classification is not governance- or audit-ready. Please document the rationale and approve it formally.

Yes: - No: - Next: B2

Reference: DORA (2022), Art. 8

B2 (question)

Question: Does the AI system directly influence operational or financial decisions?

Description: Within critical/important functions, this question distinguishes whether the AI system itself directly makes/drives decisions or merely supports them. Direct influence leads to stricter control requirements.

Yes: B2_H No: B2_EFFECTIVE Next: -

Reference: DORA (2022), Art. 6

B2_H (leaf)

Question: High criticality -> DORA baseline + resilience testing.

Description: The system has high criticality and directly influences decisions. At minimum, the DORA baseline applies, plus additional internal controls and monitoring.

Yes: - No: - Next: T1_TLPT_APPLIES

Reference: DORA (2022), Art. 26

B2_EFFECTIVE (question)

Question: In practice, are AI recommendations mostly accepted without substantive review or implemented automatically?

Description: Even if a human formally decides, the AI may effectively drive the decision. If recommendations are typically accepted or automated, stronger controls are appropriate.

Yes: B2_H No: B2_COMPLIANCE Next: -

Reference: DORA (2022), Art. 6

B2_COMPLIANCE (question)

Question: Is the use case compliance-, risk-, or audit-related, or otherwise regulatory-decisive?

Description: If AI use influences compliance, risk steering, or audit/evidence processes, the requirements usually need to be implemented more strictly: controls and evidence must be particularly robust. In such cases, a lean control setup is often insufficient.

Yes: B2_M_ENH No: B2_M Next: -

Reference: DORA (2022), Art. 6

B2_M (leaf)

Question: Medium criticality -> DORA baseline according to criticality.

Description: The system is relevant for important functions but does not make fully automated decisions. The DORA baseline can be implemented proportionately according to criticality and risk.

Yes: - No: - Next: B4

Reference: DORA (2022), Art. 6

B2_M_ENH (leaf)

Question: Medium criticality -> enhanced DORA baseline.

Description: Even without direct decision authority, compliance-adjacent use cases can trigger heightened requirements. Here, the full DORA baseline applies, including governance and controls.

Yes: - No: - Next: B4

Reference: DORA (2022), Art. 6

B3 (question)

Question: Is AI used only in a supporting capacity?

Description: This checks whether the AI system is used, but only plays a subordinate, non-critical role. Even then, baseline DORA requirements may still be relevant.

Yes: B3_N No: B3_R Next: -

Reference: DORA (2022), Art. 6

B3_N (leaf)

Question: Non-critical AI support -> DORA baseline according to criticality.

Description: The AI is used only in a supporting way and not in critical core processes. Baseline ICT controls apply, but they are less extensive.

Yes: - No: - Next: B4

Reference: DORA (2022), Art. 6

B3_R (leaf)

Question: Criticality unclear -> conservative classification and documentation.

Description: If criticality is unclear, a conservative classification should be chosen and documented properly. DORA requirements should be interpreted more strictly rather than too lightly.

Yes: - No: - Next: T1_TLPT_APPLIES

Reference: DORA (2022), Art. 8

T1_TLPT_APPLIES (question)

Question: Is your organization subject to advanced resilience testing (TLPT) under DORA (Arts. 26-27) or to a corresponding supervisory TLPT order?

Description: TLPT does not become mandatory automatically just because of criticality. The obligation typically depends on the classification or order applicable to the organization. Even if TLPT does not apply, a general testing program under Arts. 24-25 is still required.

Yes: T1_TLPT No: B4 Next: -

Reference: DORA (2022), Art. 26–27

T1_TLPT (leaf)

Question: TLPT required -> apply TLPT obligations in addition to the testing program.

Description: If TLPT applies, additional TLPT-specific requirements are added on top of the general testing-program obligations.

Yes: - No: - Next: B4

Reference: DORA (2022), Art. 26–27

B4 (question)

Question: Is the system provided, wholly or partly, by an external ICT service provider?

Description: This question clarifies whether the AI system is obtained as an external service, for example via a cloud or AI platform. That determines which DORA requirements for ICT third-party providers apply.

Yes: B4_GENAI_LLM_SERVICE No: B6 Next: -

Reference: DORA (2022), Art. 28

B4_GENAI_LLM_SERVICE (question)

Question: Is a generative AI/LLM/foundation-model service (API) used, or a comparable external service for generative AI?

Description: This path addresses specific generative-AI risks such as data minimization/redaction, retention, provider assurances, model versioning/change notices, prompt/response logging, security filters, and abuse prevention. If you use an external ICT service but not an LLM/generative-AI service, choose no.

Yes: W_DORA_GENAI_LLM_KONTROLLEN No: B5 Next: -

Reference: DORA (2022), Art. 9 / Art. 28–30

W_DORA_GENAI_LLM_KONTROLLEN (leaf)

Question: Generative AI/LLM service used -> review and implement specific generative-AI controls.

Description: This node generates additional findings/requirements for generative AI/LLM without interrupting the DORA path. It systematically addresses common audit gaps such as assurances against training on customer data, version/change management, logging, and security/abuse controls.

Yes: - No: - Next: B5

Reference: DORA (2022), Art. 9 / Art. 28–30

B5 (question)

Question: Would a provider outage in the short term impair a critical/important function or key regulatory obligations?

Description: Potential criticality is assessed via impact and dependency. If an outage would break your RTO/RPO or your ability to meet regulatory obligations, that is a strong indicator of criticality.

Yes: B5_SUBSTITUIERBARKEIT No: B5_KONZENTRATION Next: -

Reference: DORA (2022), Art. 28–29

B5_SUBSTITUIERBARKEIT (question)

Question: Is there a realistic exit/substitution option, contractually and technically, within a defined timeframe?

Description: Exit does not only mean terminating the contract; it means being able to migrate in practice, including data portability, interfaces, migration path, and tested procedures.

Yes: B5_KONZENTRATION No: B5_C Next: -

Reference: DORA (2022), Art. 28–30

B5_KONZENTRATION (question)

Question: Is there a concentration risk, for example the same provider serving multiple critical services, regions, or BCM scenarios?

Description: Concentration risk arises, for example, when the AI provider combines data hosting, inference, and core platform services, creating shared failure domains.

Yes: B5_C No: B5_N Next: -

Reference: DORA (2022), Art. 28–29

B5_C (leaf)

Question: Potentially critical ICT third-party provider -> enhanced third-party obligations.

Description: Potentially critical ICT third-party providers are subject to enhanced DORA requirements, especially around monitoring, concentration risks, exit strategies, and possibly supervisory interaction.

Yes: - No: - Next: B5_KRITIKALITAETS_UEBERPRUEFUNG

Reference: DORA (2022), Art. 28

B5_N (leaf)

Question: Non-critical ICT third-party provider -> standard obligations.

Description: The ICT service provider is not classified as critical. Normal DORA requirements for ICT third-party providers apply, proportionate to the risk.

Yes: - No: - Next: B5_KRITIKALITAETS_UEBERPRUEFUNG

Reference: DORA (2022), Art. 28

B5_KRITIKALITAETS_UEBERPRUEFUNG (question)

Question: Is the classification documented and formally approved by the compliance team?

Description: For the classification to be governance-ready, you need evidence and formal ownership through approval.

Yes: B7 No: W_DORA_DRITTANBIETER_UEBERPRUEFUNG Next: -

Reference: DORA (2022), Art. 28–30

W_DORA_DRITTANBIETER_UEBERPRUEFUNG (leaf)

Question: Third-party criticality: review/documentation required.

Description: Please complete the classification: dependency, concentration, exit strategy at least planned, plus formal approval.

Yes: - No: - Next: B7

Reference: DORA (2022), Art. 28–30

B6 (leaf)

Question: No external ICT service provider -> internal responsibility (DORA baseline).

Description: The AI system is operated entirely in-house. The organization bears full technical and organizational responsibility for operation, security, and resilience.

Yes: - No: - Next: B7

Reference: DORA (2022), Art. 6

B7 (question)

Question: Are live customer, transaction, or other sensitive data transferred to external AI services?

Description: This question focuses on data flows: are sensitive or production data transferred to external AI services? That determines the requirements for safeguards, encryption, and contractual protections.

Yes: B7_S No: B7_N Next: -

Reference: DORA (2022), Art. 9

B7_S (leaf)

Question: Sensitive data -> safeguards for external AI.

Description: If production or sensitive data are transferred to external AI, strong safeguards are required: data classification, encryption, prevention of data loss, logging, and clear contractual protections.

Yes: - No: - Next: B7_RUECKFALL

Reference: DORA (2022), Art. 9

B7_N (leaf)

Question: No sensitive data -> baseline measures sufficient.

Description: If no production or critical data are transferred to external AI, standard security measures are generally sufficient. Documenting the assumptions remains important, however.

Yes: - No: - Next: B7_RUECKFALL

Reference: DORA (2022), Art. 6

B7_RUECKFALL (question)

Question: Is there a tested fallback procedure including RTO/RPO, roles, runbook, and decision criteria?

Description: What matters is not whether fallback is theoretically possible, but whether it actually works with clear roles, a runbook, and tested times such as RTO/RPO.

Yes: B7_RUECKFALL_OK No: B7_RUECKFALL_LUECKE Next: -

Reference: DORA (2022), Art. 11–12

B7_RUECKFALL_OK (leaf)

Question: Fallback procedure exists -> BCM requirements met.

Description: Evidence should be available: runbook, BCM mapping, and test records including date, scope, and result.

Yes: - No: - Next: B8

Reference: DORA (2022), Art. 11–12

B7_RUECKFALL_LUECKE (leaf)

Question: Fallback procedure missing -> BCM mapping and testing required.

Description: Without a tested fallback procedure, there is a risk that an AI or provider outage will stop critical processes or breach regulatory obligations.

Yes: - No: - Next: B8

Reference: DORA (2022), Art. 11–12

B8 (question)

Question: Does the model change during operation?

Description: This checks whether the model changes during operation, meaning a dynamic model, or remains static. Dynamic models require stronger change-management and monitoring processes.

Yes: B8_D No: B8_S Next: -

Reference: DORA (2022), Art. 9

B8_D (leaf)

Question: Dynamic model -> monitoring/change management + incident management.

Description: For dynamic models, structured change, approval, and monitoring processes are mandatory: change monitoring, performance checks, documentation of changes, and clear escalation paths.

Yes: - No: - Next: C1_KOMMUNIKATION_BENOETIGT

Reference: DORA (2022), Art. 17

B8_S (leaf)

Question: Static model -> baseline measures + incident management.

Description: Even with static models, approvals and change management are required. Because updates usually happen less often, review and release activities can typically be planned at a lower cadence, but each change still needs to be documented transparently and reviewed before go-live. In addition, functioning incident management must be in place.

Yes: - No: - Next: C1_KOMMUNIKATION_BENOETIGT

Reference: DORA (2022), Art. 17

C1_KOMMUNIKATION_BENOETIGT (question)

Question: Could an outage or incident have customer, market, or reputational impact, such that external communication may be required?

Description: DORA requires communication plans and strategies for internal and external stakeholders. If customers or the public may be affected, a robust communication plan including approvals and severity levels should exist.

Yes: W_DORA_KOMMUNIKATION_ERFORDERLICH No: ENDE Next: -

Reference: DORA (2022), Art. 14 i. V. m. Art. 17

W_DORA_KOMMUNIKATION_ERFORDERLICH (leaf)

Question: Communication plans/strategy required under DORA Art. 14.

Description: Add a communication plan to the incident runbook, internal and external, with approvals, audience logic, and templates.

Yes: - No: - Next: ENDE

Reference: DORA (2022), Art. 14

ENDE (leaf)

Question: Analysis completed.

Description: -

Yes: - No: - Next: -

Reference: -